

Bank of Bahrain & Kuwait — Data Protection Policy

Policy No. BBK-LGL-020 | Version 1.0 | Classification: Internal

Issuing Authority: Legal & Compliance Department | Effective Date: 1 January 2025

Section 1: Purpose and Scope

This Policy sets out how Bank of Bahrain and Kuwait (the Bank) collects, uses, stores and protects the personal data of its customers, employees and counterparties. It applies to all staff, departments, branches and third parties that process personal data on the Bank's behalf. The Policy is intended to ensure that personal data is handled lawfully, fairly and securely across all banking operations.

Section 2: Definitions

For the purposes of this Policy, personal data means any information relating to an identified or identifiable natural person. Processing means any operation performed on personal data, whether by automated means or otherwise. A data subject is the natural person to whom the personal data relates. The controller is the Bank department that determines the purposes and means of processing.

Section 3: Lawful Basis for Processing

The Bank shall only process personal data where a lawful basis exists. Acceptable bases are: the performance of a banking contract with the customer; compliance with a legal or regulatory obligation, including anti-money-laundering and know-your-customer requirements; the legitimate interests of the Bank where these are not overridden by the rights of the data subject; and the freely given consent of the data subject. The lawful basis relied upon shall be documented for each processing activity.

Section 4: Consent Management

Where processing relies on consent, the Bank shall obtain the consent of the data subject through a clear affirmative action before processing begins. Consent requests shall be presented separately from other terms and in plain language. A data subject may withdraw consent at any time, and the Bank shall make withdrawal as easy as giving consent. Records of consent shall be retained by the relevant department.

Section 5: Rights of the Data Subject

The Bank respects the rights of data subjects. A data subject may request access to the personal data the Bank holds about them, and may request the rectification of inaccurate or incomplete data. A data subject may request the erasure of their personal data where it is no longer necessary for the purpose for which it was collected, subject to the Bank's legal retention obligations. Requests shall be handled by the Compliance Department within thirty (30) days.

Section 6: Data Retention and Disposal

Personal data shall be retained only for as long as necessary to fulfil the purpose for which it was collected or as required by applicable banking and anti-money-laundering law. The Bank maintains

a retention schedule specifying retention periods for each category of record. Upon expiry of the retention period, personal data shall be securely destroyed or anonymised so that it can no longer be attributed to a data subject.

Section 7: Information Security Measures

The Bank implements appropriate technical and organisational measures to protect personal data against unauthorised access, alteration, disclosure or destruction. These measures include encryption of data in transit and at rest, role-based access controls, network segmentation, logging and monitoring of access to customer data, and regular security testing. Access to personal data is granted on a least-privilege, need-to-know basis.

Section 8: Personal Data Breach Notification

In the event of a personal data breach, the department that identifies the breach shall notify the Compliance Department without undue delay. The Compliance Department shall assess the breach and, where it is likely to result in a risk to affected individuals, notify the competent supervisory authority. The Bank shall maintain an internal register of all personal data breaches, including the facts of the breach and the remedial action taken.

Section 9: Staff Training and Awareness

All staff who process personal data shall receive data protection training upon joining the Bank and at regular intervals thereafter. Training shall cover the requirements of this Policy, the identification and reporting of data breaches, and the handling of data subject requests. Departmental heads are responsible for ensuring their staff complete the required training.

Section 10: Policy Review and Governance

This Policy shall be reviewed at least annually by the Legal and Compliance Department, and updated to reflect changes in applicable law, regulation or the Bank's operations. Breaches of this Policy by staff may result in disciplinary action. Questions regarding the interpretation or application of this Policy should be directed to the Compliance Department.